

Leof. Kifisias 1-3, 11523 Athens

T: 210 6475 600 • E: contact@dpa.gr • www.dpa.gr

Athens, 11-10-2024

Ref. No.: 2754

DECISION 37/2024

(Section)

The Hellenic Data Protection Authority convened, following an invitation from its President, in a regular meeting in the composition of a Section at its headquarters on 24/7/2024 in order to examine the case referred to in the background of this document. Present at the meeting via videoconference were Georgios Batzalexis, Deputy President, due to the absence of the President of the Authority, Konstantinos Menoudakos, Demosthenes Bougioukas substituting for the regular member Konstantinos Lamprinoudakis, and Maria Psalla, as rapporteur and substituting for the regular member Grigorios Tsolias, who, although duly summoned in writing, did not attend due to an impediment. Also present at the meeting, by order of the President without voting rights, were Charis Symeonidou and Georgia Panagopoulou, special scientists - auditors as assistants to the rapporteur, and Irini Papageorgopoulou, an employee of the administrative affairs department of the Authority, as secretary.

The Authority took into account the following:

With complaint No. G/EIS/3284/04-05-2023 submitted to the Authority, A reported that on 4/5/2023 at 17:56 she received a message (sms) on her personal mobile phone with the following content: "... (FB: ...)", which she attached to the complaint. As the complainant states, she has never personally known the said individual, was unaware of his existence, and after connecting with his account on Facebook, she saw that he is a Curator ... at the ... Clinic of Hospital X, a hospital that the complainant mentions she has visited many times as a patient and as an escort for minor patients. For this reason, the complainant complains about the unsolicited political communication and the violation of her sensitive personal data, as she claims.

Subsequently, with complaint No. G/EIS/3322/05-05-2023, B stated that she is reporting G for the violation of her personal data as a patient for the purposes of his political campaign, claiming that the respondent obtained her information, her phone number, and her medical history from Hospital X without her permission or notification, and used it to send her the aforementioned sms message ("...(fb: ...)"). As the complainant states, this message caused her distress as it refers to a very painful event in her life, her illness ... for which she was hospitalized at Hospital X [...], while she continues to visit the hospital regularly to this day, and because of the reported message, she now "feels threatened" by the fact that anyone can take the data she provides to the hospital for the purpose of her medical care and use it as they wish.

Alongside complaint No. G/EIS/3383/08-05-2023 regarding a data breach incident and its supplementary documents, Hospital X notified the Authority under Article 33 of the GDPR of the following factual circumstances: "On 05/05/2023, the Hospital received a letter from the affected data subject, informing the Hospital that on 04/05/2023 she received a political communication message [with the following content: "... (FB: ...)"], from a physician - candidate for Parliament, who has not worked at the Hospital since In this way, the Hospital was informed of the fact that the physician - former employee of the Hospital, either upon his departure or at an earlier time, extracted personal data from the Hospital's systems (to which he had lawful access for the purposes of performing his medical duties) and used it for other, incompatible purposes. The

The Hospital is unable to ascertain exactly when the incident of breach occurred, namely the unlawful extraction of personal patient data from the Hospital, given that the specific doctor had access to patient records in his department throughout his employment at the hospital, solely for purposes

related to the provision of medical services. Furthermore, the Hospital cannot accurately determine the time of conclusion of the incident, and for this reason, the date of the doctor's departure from the Hospital has been filled in as the conclusion date of the incident, namely on ...". Following the above, and as evidenced by the relevant supplementary documents of the Hospital (Γ/ΕΙΣ/4452/14-06-2023), a non-judicial declaration – invitation – protest and reservation was sent on behalf of the Hospital on 08/05/2023, in which the Hospital informed the accused of the above and called upon him to promptly inform the Hospital if he had received a copy or recorded in his personal file any patient data from the Hospital, when and how, which data he had received and for which patients, as well as to return them immediately, so that the Hospital could consider any additional actions required to comply with the personal data protection legislation. In the response to the Hospital dated 19/5/2023, the accused stated that he never used the medical records of the Hospital for any reason, that the numbers of recipients of his pre-election campaign came exclusively from his personal patient records and from publicly accessible databases of mobile phone numbers via the internet, that the text of the message was unfortunate and left room for misinterpretation, however, there is no evidence of targeted personalization or reference to a patient, since the same message was sent to others, non-patients, and he generally denied the content of the above non-judicial declaration as unfounded.

In the context of investigating the above factual circumstances, the Authority, with document Γ/ΕΞΕ/1244/16-05-2023, communicated the aforementioned complaints to the accused and invited him to present his views on the allegations, providing full documentation and clarifying in particular a) which personal data he processes for the purposes of political communication, what the source of these data is, and what the legal basis for their processing is, and b) how he informs the data subjects about the aforementioned processing of their data, in accordance with the principle of transparency of processing (Article 5(1)(a) GDPR). It is noted that the Authority's letter was initially sent by mail to the address where the above non-judicial letter from the Hospital had been served to him, and it was returned undelivered. For this reason, the same letter was resent via electronic mail after the Authority learned the email address of the complainant from the Hospital, with document Γ/ΕΙΣ/4631/21-06-2023.

In his response to the Authority, with reference number Γ/ΕΙΣ/5784/08-08-2023, the accused replied as follows:

- That the claims of the complainants regarding the illegal collection and processing of their data for the purpose of political communication are unfounded, because, in the context of his pre-election campaign as a candidate for parliament ..., he sent mass SMS, including the controversial message sent on 4/5/2023, to individuals within his personal circle, to individuals who are members of ..., to his patients (personal friends, acquaintances, colleagues, and individuals who have previously participated in events and actions he has organized), and to recipients obtained after using a telephone number generator (www.ekepis.gr) and from publicly accessible directories, while a third-party SMS sending company was used for this purpose as the processor.
- That the content of the message ("...") has no relation to the medical history of its recipients, which he could not know, according to the Code of Medical Ethics (Law 3418/2005), and that the wording of the message aimed to emphasize his role as ... of the NHS, who knows the internal issues and can address them.
- That due to his increased workload (...) and the limited budget he could allocate to his pre-election campaign, the accused claims he did not have the opportunity to be aware of the latest developments regarding political communication, the new Guidelines 1/2023 of the Authority, and the obligations of transparency in...

5

- Any political communication or hiring of a consultant to guide him.
- That he conducted the said communication with consideration of "the previous regime," and that he brought to the attention of the recipients his personal Facebook page, so they could submit any request for access and/or deletion and/or objection.
- That a few days after sending the message, he was informed by the [party] about the minimum

transparency requirements that every unsolicited political communication must meet, and that immediately thereafter he proceeded with the necessary changes, despite the costs involved (due to the number of characters, each SMS now cost as much as 3), specifically the following compliance actions: a) the formulation of a consent form, accompanied by a relevant information note for the processing of personal data (for future processing), b) the removal from the list of recipients of all numbers he had obtained from the generator and from publicly accessible directories, and c) the formulation of an information note, which he posted on his Facebook page.

- That the legal basis for the processing was his legitimate interest (according to Article 6, paragraph 1, letter f of the GDPR) to communicate his political activity, positions, and ideas as a candidate for parliament, particularly due to his professional background in the National Health System, in the context of the parliamentary elections of 21/5/2023 and 25/6/2023, which derives from his constitutional rights to participate in the political life of the country, to express himself freely, to organize assemblies, and to communicate about them, and that with the sole purpose of being able to inform the voters of ... about his actions, he maintains a record of electronic communication recipients with data collected from various sources over the years, given that he is generally socially active (having served as a board member of the Medical Associations ... and ...). Regarding the balancing of his interest with the rights of the recipients of the communication, the respondent notes that sending text messages "allows the above constitutional rights to be exercised more easily, effectively, and to a larger segment of citizens, achieving, in extension, greater representativeness in the electoral body of the regional unit of At the same time, abstaining from making communications with these means and for this purpose harms the core of the pursued interest and right related to my participation in political life. Therefore, in the manner in which the pursued purpose was carried out in this case - assessed in conjunction with the type of data used, which was limited to the communication data of the subjects without processing identification data - the rights of the affected persons-recipients of the communication regarding the protection of their personal data were not excessively infringed. Following the above, it emerges that the processing in question is necessary and essential for the intended purpose."

- Regarding the proportionality of the processing based on its impact on the rights of individuals, the respondent argues that only the contact details (phone numbers) were utilized for this processing without any processing of other identification data (e.g., name and surname) of the recipients, and that the rights and freedoms of the subjects are not disrupted through the conducted political communication because the said purpose, within the framework of this specific processing, is defined, explicit, lawful, and serves the exercise of fundamental constitutional rights.

- That the claim that he collected the complainants' data from the records of Hospital X is unfounded and offensive, that he used a number generator, and that the correlation of the database of his communication recipients with the hospital's patient registry, beyond being excessive and disproportionate processing, would not be technically possible for him, as such capability is not provided by the hospital's systems.

- Regarding the first aforementioned complaint, the respondent states that a number generator was used and therefore it was not possible to know the recipient's details, refuting as false and offensive the...

7

the claim that he collected the complainant's phone number from the patient registry of the ... clinic of Hospital X.

- Regarding the second complaint mentioned above, the respondent argues that it is vague, unsubstantiated, and unfounded, emphasizing that the complainant does not mention the number to which the message was sent, did not address him prior to filing the complaint as recommended by the Authority on its website, and that in any case, the respondent did not need to obtain the complainant's consent beforehand, given that the processing in this case was based on the legal ground of legitimate interests. Following the above, the Authority, with its letter G/EXE/2275/08-09-2023, requested the respondent to provide the following clarifications and relevant evidence: 1) To submit complete and accurate information (proof of sending, invoices, recipient lists, etc.) from which the total number of

subjects who received each of the communications via SMS mentioned on page 9 of his memorandum in the context of his electoral campaign can be determined, specifying how many phone numbers of recipients correspond to each of the 4 sources referred to by the respondent on page 10 of his memorandum. 2) To specify when and how the consent form submitted as Exhibit 3 was used by him, stating specifically how many subjects have given their consent in this manner and providing for documentation signed forms that he keeps. 3) To explain at what time and to which email address the update to the subjects, which the respondent submitted as Exhibit 4, was posted, and 4) Regarding his claim that the second complainant did not submit any request to him before filing the complaint, the Authority called upon the respondent to substantiate the ability of the subjects to exercise their rights under the GDPR towards him, as the data controller, at the time of filing the complaint, specifying exactly where he provided his contact details either to the recipients of the messages or publicly to the general public. Following the sending of the reminder letter G/EXE/2851/13-11-2023 from the Authority, the respondent, with his reply letter G/EIS/8274/21-11-2023, submitted to the Authority printed detailed reports from the Your SMS platform, which reflect the number of SMS needed for each message based on characters, the number of recipients who received the communication, and the corresponding cost. As indicated by this data, the sending of the critical SMS message (with content ... (FB: ...), hereinafter referred to as "1st communication") took place on 4/5/2023 at 05:55 to 4,772 recipients, each message corresponded to 3 SMS, and the cost amounted to 28,632 credits. Additionally, the respondent clarified that of the 4,772 recipients, 75% belong to his personal friends, acquaintances, and individuals from his immediate work circle, and generally people who have participated in past events and activities he has organized, 15% to recipients for whom a phone number generator was used, and 10% to numbers obtained from publicly accessible directories. Furthermore, from the submitted documents, the following information emerges regarding the other SMS communications made by the respondent in the context of his electoral campaign:

- 2nd communication: ...
- 3rd communication: ...
- 4th communication: ...
- 5th communication: ...

The respondent noted that he developed the consent form a few days after sending the communication under examination, the form was available in a distinct area along with cards and leaflets of other candidates, during the electoral events of ... in ... as well as at his own electoral events, while he attaches indicative completed forms as annexes. Regarding the update, the respondent physician states that it was posted on his Facebook page dated 08/08/2023, simultaneously asserting that these informational notes were also available in the consent forms he had available at his events ... and his speeches, although no evidence is provided to substantiate this claim. Finally, concerning the ability to exercise rights, the respondent

9

states the following: "As the platform I collaborated with for sending mass SMS did not provide the option for automated unsubscribe for users, I brought to the attention of the recipients of my communication, as I mention on page 10 of my Memorandum, my personal Facebook page (Ref. 3), which is public, meaning open to everyone and on which there was the possibility of communication with one click, via the relevant application of the said platform. Therefore, anyone could submit a question or any request such as access and/or deletion and/or objection. However, the manner of exercising such requests was not binding. Anyone who wished could - even verbally - submit any request (which did not happen) and this would be processed directly," emphasizing again that the second complainant did not attempt to submit any request, a fact that demonstrates the abusive nature of the complaint.

Following the above, the Authority, with its G/EXE/528/12-02-2024 summons, called the respondent to a hearing before the Authority's Department on 21/2/2024, in order to present his views on the case. During the session on 21/2/2024, the respondent, through his attorney, Stergios Konstantinou (Bar Association No. ...), requested a postponement of the case due to illness. The request was accepted,

and the case was postponed to 6/3/2024. During the session on 6/3/2024, the respondent appeared with the aforementioned attorney. He emphasized that the personal data of the complainants did not originate from Hospital X, reiterated the claim that the wording of the message was due to an "unfortunate choice" following advice he received in order to highlight his experience in the public health system and that he was not addressing the specific recipient personally but any recipient of the message, who, in his estimation, had a high probability of... actually in the NHS. The respondent argued that he was not aware of the legality requirements of the communication policy, that he managed all related operations on his own, without the use of a data processor (beyond the service yoursms), and attributed the fact that he used a phone number generator and public directories to this, noting that subsequently he took actions to improve the practices he follows, namely he created a consent form, cleared his database of numbers originating from the aforementioned two sources, and clarified that the two numbers of the complainants had originated from the random number generator ekepis.gr. The Authority granted a deadline for the submission of a memorandum until 22/3/2024 and requested that documents be submitted with the memorandum to substantiate the claim regarding the use of a generator concerning the two numbers of the complainants as well as information regarding the cost of sending the message in question. Subsequently, the Authority, with its G/EXE/878/14-03-2024 document, requested the complainant to additionally submit with his memorandum the complete list of 4,772 recipients of the message (SMS) sent on 4/5/2023, specifically stating which numbers belong to which category as mentioned in percentage form in its G/EIS/8274/21-11-2023 document. In his G/EIS/2764/26-03-2024 memorandum, the respondent initially stated that the total cost for the specific message sending amounts to 363.62 euros, while he also submitted the entire list of recipients of the message as extracted from the platform yoursms.gr, and regarding the distribution of the numbers by source of origin, he reiterated the percentages (15% from a phone number generator and 10% from publicly accessible directories), stating that he has not maintained records regarding the exact origin of each number and therefore cannot proceed with their categorization based on origin. Regarding the source of origin of the complainants' numbers, the respondent claimed that they originated from the ekepis platform, while he submitted a screenshot from the said platform, which contains all possible numbers starting with the same digits and on which the complainants' numbers have been highlighted. The memorandum also explains that in the context of proving the non-origin of the data from the records of Hospital X, a request for access to the hospital's log files regarding the extraction of files was submitted on behalf of the respondent, to which the DPO of the hospital...

11

responded that he does not possess the requested files. Thus, as the respondent argues, he cannot prove otherwise regarding the non-extraction of patient communication data from the hospital's database. Finally, in his memorandum, he emphasizes that the complainants did not substantiate the alleged processing concerning the origin of their data from the hospital, arguing that they bear the burden of proof so that the Authority can reach a safe decision and he can provide comprehensive counter-evidence, invoking the provision of Article 145 paragraph 1 of the Administrative Procedure Code (APC) as well as the generally applicable rules for evidence before the Administration during the issuance of administrative acts (according to Article 17 paragraph 3 of the APC), "in the absence of specific legislative provision," as he states.

Subsequently, and taking into account the lack of documentation regarding the origin of the recipients of the SMS message dated 4/5/2023 from the respondent according to the principle of accountability (Article 5 paragraph 2 GDPR), the Authority sent to Hospital X the document G/EXE/967/27-03-2024, in which it requested, following the notification of a breach incident, by 8/4/2024: a) to report the total number of patients who filed complaints with the Hospital regarding the receipt of the pre-election message (SMS) from doctor G, providing relevant documentation, b) to clarify whether any additional information has emerged regarding the aforementioned notification of a personal data breach and, in the case of an affirmative response, to provide such information, and c) to submit to the Authority the complete list of mobile phone numbers of patients ... from May 2018 to May 2023.

In its response document G/EIS/3530/16-04-2024, the Hospital submitted to the Authority two complaints from patients (D and E) who had received the contested pre-election message and had complained to the Hospital about the possible leak of their data in May 2023. Regarding the investigation of the incident, the Hospital informed the Authority that an internal inquiry was conducted on the matter to collect evidence, and a report was submitted under reference number ... according to which "there are serious indications that the doctor acted with negligence in violation of the rules of medical ethics, medical confidentiality, and the obligation of confidentiality." Subsequently, following the decision number ... of the Hospital's Board of Directors, it was decided to refer the case to the Central Disciplinary Council of Physicians of the National Health System (C.D.C.), which issued an acquittal decision, without calling the doctor to account. The Hospital submits an excerpt from the meeting of the Central Disciplinary Council of Physicians of the National Health System, according to which "the Council, after examining all the documents of the disciplinary file and mainly taking into account what was stated by the lawyer and the accused doctor [...] unanimously decides to acquit without calling the doctor G to account" for the disciplinary offenses attributed to him by the decision number ... of the Hospital's Board of Directors. Additionally, the Hospital submitted to the Authority an Excel file consisting of 6,707 mobile phone numbers, ... from the last 5 years.

From the comparison of the two mobile phone files submitted to the Authority as mentioned above, it appears that out of the 4,772 recipients of the SMS message from the respondent dated 4/5/2023, 3,392 are included in the file of mobile phone numbers of patients ... at Hospital X over the last 5 years. It is also noted that in both lists, 17 numbers were identified that contain the same error, meaning they consist of either fewer or more than 10 digits. Meanwhile, in his letter G/EIS/3237/08-04-2024, the Ombudsman forwarded to the Authority the reference number ... from S, which stated that she received the pre-election message from the respondent dated 4/5/2023, while she was registered at Hospital X in 2022.

Following the above, with the summons G/EXE/1170/16-04-2024, the Authority again summoned the respondent to a hearing before the Department of the Authority on Wednesday, 24/04/2024, simultaneously notifying him of the new evidence that had come to its knowledge. During the meeting on 24/4/2024, the respondent was present with his aforementioned legal representative. Responding to the new evidence, the respondent argued that the fact that a large percentage of the recipients of his pre-election message from 4/5/2023 were also patients of Hospital X does not prove that he extracted

13

the mobile phone numbers from the Hospital's records, but that the same patients belonged to the category of "personal friends and acquaintances," which he initially identified as the source of the recipients of his message, noting that he had inadvertently failed to clarify to the Authority that this category also included "his personal patients," meaning patients he had treated himself during his 36 years of employment, including patients from Hospital X. The respondent clarified that he has been working at Hospital X since 2018 and, as ..., ... a very large number of patients, which in some cases could reach ... per day. In response to a related question from a member of the Authority, the respondent clarified that by patients he had treated, he does not only mean those ... but also those who may have needed his assistance at a later stage, e.g., requesting some medical opinion or other document from the Hospital. As he argued, he considers these to be "his own patients," as he personally treated these patients. Specifically, as he mentions in his memorandum, "in order to facilitate communication with the patients of the hospital, he created a physical file, an agenda with the names and contact details of the patients, with whom he communicated ... in order to respond to their inquiries," and he stated to the Authority that this agenda has now been destroyed. During the hearing, the respondent reiterated that regarding the complainants, their numbers came from the ekepis generator, as did several other recipient numbers. He utilized the generator in order to make use of the full SMS package he had purchased for his specific electoral campaign, as this allowed him to send messages to more recipients than he had available in his agenda. In response to a question about how he knows that a specific number came from the generator or from his agenda, given that he keeps no

documentation, he stated that "he remembers all" his acquaintances and patients, therefore any recipients who do not belong to those he remembers came from the generator. Regarding the 17 common erroneous numbers found on both lists (his and the Hospital's), the respondent argued that this fact can be explained, as in several cases he collected the patients' details and then provided them to the Hospital's Secretariat to be recorded in the Hospital's electronic records, stating that the daily practice in managing patients differs from the theoretical process.

During the session, a deadline was granted for the submission of a memorandum until 14/6/2024, which was extended until 1/7/2024 by the Authority's document G/EXE/1643/13-06-2024, given that new evidence regarding the case was to be presented to the respondent. In this context, following communication between the Authority and Hospital X, the Hospital's document G/EIS/5292/18-06-2024 describes the process of declaring and recording patients' demographic data in the Hospital's program and clarifies that this information is only declared by the patients in person at the Outpatient Clinic Secretariat and that no intervention or modification of their file data is allowed by a third party. Additionally, with the Hospital's document G/EIS/5410/21-06-2024, the Authority received the report No. ... of the Administrative Inquiry (EDE). From this report, it appears that the main claim of the doctor within the EDE was that the phone numbers of the recipients of his message came from a random number generator, and the content of the message aimed to demonstrate his professional capacity as ... and was not related to the status of the citizens The explanations provided by the doctor within the EDE were not deemed convincing, and taking into account the doctor's access to the program with patient data and the ease of copying data from the program, which did not record, at the time of the actual events, a detailed history of actions per user, the EDE concludes that "there are serious indications that he acted with negligence in violation of the rules of medical ethics, medical confidentiality, and the obligation of confidentiality." With the Authority's transmittal document G/EXE/1755/26-06-2024, the above documents were communicated to the respondent so that he could be informed in view of submitting a memorandum by 1/7/2024.

15

In his memorandum G/EIS/5613/02-07-2024, the respondent states the following:

- That for the medical records of patients at Hospital X, the Data Controller is the hospital itself. Doctors are not provided with digital or physical copies of the patients' Medical Files or the ability for remote access. Access to the patient's file is only possible from the hospital's computers. However, it was not possible to extract data from the hospital's information system, and even if it were, the doctor was not aware of this possibility nor did he receive any relevant training regarding it.
- That in order to facilitate communication with the patients of the hospital, he created a physical file, an agenda with the names and contact details of the patients with whom he communicated... in order to respond to their inquiries, as is standard practice followed by all doctors to manage whatever arises for the patients and to ensure that they feel secure regarding their health.
- That the legal basis for maintaining the file was the legitimate interest of the patients concerning the immediate management and response to any inquiries/questions or concerns... as well as being necessary for preventive or occupational medical purposes (Article 6 para. 1 point (f) GDPR & Article 9 para. 2 point (h) GDPR).
- That he always had this agenda with him and did not leave it exposed in shared spaces such as the office he shares with colleagues.
- Regarding the Report of the Internal Investigation, he claims that this document was transmitted under the confidential protocol number... to the Central Disciplinary Council of Doctors of the National Health System (submitted as Relevant 1) with a question of whether or not to place him on potential leave. In the context of examining this issue, the doctor states that he was summoned for a hearing on... before the Central Disciplinary Council of Doctors of the National Health System (submitted as Relevant 2) and after presenting, explaining, and proving both the factual circumstances and the reasons why the document number G/EIS/5410/21-06-2024 was based on unsupported and unfounded conclusions, the Disciplinary Council proceeded to fully acquit him

16

both based on the factual circumstances and due to substantial violations by the hospital during the conduct of the Internal Investigation (submitted as Relevant 3).

- Regarding the wording of the communication, the doctor submits as Relevant 4 an affidavit from the communication consultant Z, who had taken on his communication strategy and confirms that he had suggested the said wording purely for communication purposes without knowing the identity of the recipients of the message.

The Authority, after examining the file's evidence and having heard the rapporteur and clarifications from the assistant rapporteurs, after thorough discussion

CONSIDERED IN ACCORDANCE WITH THE LAW

1. From the provisions of Articles 51 and 55 and Article 9 of Law 4624/2019 (Government Gazette A' 137), it follows that the Authority has the competence to supervise the application of the provisions of the General Regulation (EU) 2016/679 for the protection of natural persons against the processing of personal data (hereinafter GDPR), this law, and other regulations concerning the protection of individuals from the processing of personal data. According to the above findings and from the provisions of Articles 57 para. 1 point (f) of the GDPR and 13 para. 1 point (g) of Law 4624/2019, it follows that the Authority has the competence to address the complaints of A and B regarding the unlawful processing of their personal data and to exercise, respectively, the powers conferred upon it by the provisions of Articles 58 of the GDPR and 15 of Law 4624/2019.

2. Article 5 para. 1 of the GDPR sets out the principles that must govern processing. According to Article 5 para. 1 (a) GDPR "1. Personal data shall be: (a) processed lawfully and fairly in a transparent manner in relation to the data subject ('lawfulness, fairness, and transparency'). Furthermore, according to the principle of accountability expressly defined in the second paragraph of the same article and which constitutes a cornerstone of the GDPR, the data controller "bears the responsibility and is able to demonstrate the

17

Compliance with paragraph 1 ("accountability"). This principle entails the obligation of the data controller to be able to demonstrate compliance with the principles of Article 5 paragraph 1. This principle regarding the burden of proof before the Authority constitutes a specific provision of the legislation for the protection of personal data and therefore prevails over the general rules regarding the burden of proof in the Code of Administrative Procedure.

3. According to Article 6 paragraph 1 of the GDPR, "1. Processing shall be lawful only if and to the extent that at least one of the following applies: a) the data subject has given consent to the processing of his or her personal data for one or more specific purposes; b) processing is necessary for the performance of a contract to which the data subject is a party or in order to take steps at the request of the data subject prior to entering into a contract; c) processing is necessary for compliance with a legal obligation to which the controller is subject; d) processing is necessary to protect the vital interests of the data subject or of another natural person; e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller; f) processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular if the data subject is a child." Recital 47 of the GDPR further clarifies: "The legitimate interests of the controller, including those of a controller to whom the personal data may be disclosed or a third party, may provide the legal basis for processing, provided that they are not overridden by the interests or fundamental rights and freedoms of the data subject, taking into account the reasonable expectations of data subjects based on their relationship with the controller. Such a legitimate interest could exist, for example, when there is a relevant and appropriate relationship between the data subject and the controller, such as when the data subject is a customer of the controller or is in the service of the controller. In any case, the existence of a legitimate interest would require careful assessment, including as to whether the data subject, at the time and in the context of the collection of personal data, could reasonably expect that processing for that purpose could take place. In particular, the interests and fundamental rights of

the data subject could override the interests of the controller when personal data are processed in circumstances where the data subject does not reasonably expect further processing of their data." Furthermore, according to Article 9 of the GDPR, as a rule, "1. The processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, data concerning health, or data concerning a natural person's sex life or sexual orientation shall be prohibited," unless one of the exceptions provided for in paragraph 2 of the same article applies. When the legal basis for processing is consent, it must be given in accordance with the definition in Article 4 paragraph 11 of the GDPR ("any indication of the data subject's wishes, freely given, specific, informed, and unambiguous, by which the data subject signifies agreement, by a statement or by a clear affirmative action, to the processing of personal data relating to him or her") and must also meet the requirements for valid consent under Article 7 of the GDPR.

4. According to paragraph 4 of Article 6 of the GDPR, "Where processing for a purpose other than that for which the personal data have been collected is not based on the consent of the data subject or on Union or Member State law which constitutes a necessary and proportionate measure in a democratic society to safeguard the objectives referred to in Article 23 paragraph 1, the controller, in order to determine whether the processing for another purpose is compatible with the purpose for which the personal data were initially collected, shall take into account, inter alia: a) any relationship between the purposes for which the personal data have been collected...

19

personal data and the purposes of the intended further processing, b) the context in which the personal data were collected, particularly regarding the relationship between the data subjects and the data controller, c) the nature of the personal data, especially concerning the special categories of personal data being processed, in accordance with Article 9, or whether personal data related to criminal convictions and offenses are being processed, in accordance with Article 10, d) the potential consequences of the intended further processing for the data subjects, e) the existence of appropriate safeguards, which may include encryption or pseudonymization." In Recital 50 of the GDPR, it is emphasized that "To determine whether the purpose of the further processing is compatible with the purpose of the initial collection of personal data, the data controller, provided that all requirements for the legality of the initial processing are met, should take into account, among other things: any links between those purposes and the purposes of the intended further processing; the context in which the personal data have been collected, in particular the reasonable expectations of the data subject based on their relationship with the data controller regarding the further use of their data; the nature of the personal data; the consequences of the intended further processing for the data subjects; and the existence of appropriate safeguards for both the initial and the intended further processing acts."

5. Regarding the transparency of processing, Article 12(1) of the GDPR states that: "The data controller shall take appropriate measures to provide the data subject with all information referred to in Articles 13 and 14 and any communication in accordance with Articles 15 to 22 and Article 34 regarding processing in a concise, transparent, intelligible, and easily accessible form, using clear and plain language, particularly when addressing children. The information shall be provided in writing or by other means, including, where appropriate, electronically. When requested by the data subject, the information may be provided orally, provided that the identity of the data subject is proven by other means." The mandatory information to be provided is specified in Article 13 of the GDPR for cases where data is collected from the data subject and in Article 14 of the GDPR for cases where the data has not been collected from the data subject. Specifically, this information includes at least "a) the identity and contact details of the data controller and, where applicable, of the controller's representative, b) the contact details of the data protection officer, where applicable, c) the purposes of the processing for which the personal data are intended, as well as the legal basis for the processing, d) the relevant categories of personal data, e) the recipients or categories of recipients of the personal data, f) where applicable, that the data controller intends to transfer personal data to a recipient in a third country or an international organization and relevant information, g) the period for which the data will be stored, or, if that is not possible, the criteria used to determine that period, h) information

regarding the rights of the data subject under Articles 15-22 of the GDPR." Furthermore, according to paragraph 3 of the same article, "When the data controller intends to further process the personal data for a purpose other than that for which the personal data were collected, the data controller shall provide the data subject, prior to that further processing, with information on that purpose and any other necessary information, as referred to in paragraph 2." If the data has not been collected from the data subject, according to Article 14(2)(f) of the GDPR, it is required to provide the data subject with information "on the source from which the personal data originate and, where applicable, whether the data originated from publicly accessible sources." The information is provided either at the time of collection of the data, when collected from the data subject (Article 13 of the GDPR), or within the time period specified in paragraph 3 of Article 14 of the GDPR, in cases where the data has not been collected from the data subject and specifically, if it is to be used for communication with the data subject, at the latest...

21

upon the first communication with the data subject (Article 14, paragraph 3, point b) of the GDPR). It is also noted that according to Article 12, paragraph 2 of the GDPR, the data controller is obliged to "facilitate the exercise of the rights of data subjects as provided for in Articles 15 to 22."

6. Regarding political communication, following the decisions No. 1343-5/2022 of the Council of State, which ruled that the activity of political communication, not aimed at commercial promotion, does not fall under Law 3471/2006, the Authority re-examined, within the framework of its competence, the legality issues arising in relation to political communication in order to determine the framework for the lawful processing of personal data for this purpose based on the provisions of the GDPR. With Decision 9/2023¹, it decided to issue Guidelines 1/2023 for the processing of personal data for the purpose of political communication. With these Guidelines (hereinafter referred to as "Guidelines 1/2023"), it is clarified, among other things, that: "The processing of personal data for the purpose of political communication may be based either on the prior consent of the data subjects (Article 6, paragraph 1, point a of the GDPR) or on a legitimate interest that may arise (Article 6, paragraph 1, point f of the GDPR). It is clarified in this regard that, when personal data has been lawfully collected initially for another purpose and the further use for the purpose of political communication is not based on the consent of the data subject, the processing is lawful if the data controller demonstrates that the processing for the purpose of political communication is compatible with the purpose for which the personal data was initially collected and the conditions of Article 6, paragraph 4 of the GDPR are met. Indicative cases for the application of the above legality conditions are included in this text in paragraph 2.1.2."

Furthermore, with Guidelines 1/2023, it is reminded that "in the case of data collection for use for the purpose of political communication based on the legitimate interest (Article 6, paragraph 1, point f of the GDPR), according to the principle of accountability under Article 5, paragraph 2 of the GDPR, the data controller must be able to sufficiently document the balancing test that must have been conducted prior to the commencement of processing, and based on which it assessed that the interests of the data subject do not outweigh the interests or fundamental rights and freedoms of the data subjects - recipients of the political communication."

As indicative examples of cases in which personal data may not be used for the purpose of political communication, Guidelines 1/2023 list the following:

- If the candidate has collected email addresses and/or phone numbers from the internet using a web crawler
- If the candidate has purchased a list of citizens' contact details from a third company, even if there is consent for their use for the purpose of commercial promotion of products/services
- If the candidate has collected contact details of professionals from directories or public registers posted on the internet for transparency or professional communication purposes
- If the candidate who held a public position has collected citizens' data that they provided in the context of their transactions with his/her service.

Regarding the information of data subjects according to Articles 13 and 14 of the GDPR, Guidelines

1/2023 emphasize that the information must be concise, transparent, understandable, easily accessible, and expressed in plain and clear language, in accordance with Article 12, paragraph 1 of the GDPR.

Finally, specifically for the case of electronic communication, the following is noted: "Correspondingly, in every electronic communication for the purpose of political communication, it is required:

- to clearly and distinctly state the identity of the sender or the person for whose benefit the message is sent,
 - to clarify the source from which the contact details of the data subject have been collected, if it is not the data subject themselves (Article 14, paragraph 2, point f),
 - to refer to the full text of the information in accordance with Articles 13 or 14 of the GDPR and
- 23

- The method by which the recipient of the message can exercise their rights, including the right to request the termination of communication (right to object) must be stated.

7. In this case, from the elements of the file and following what emerged during the hearing process, it is established that the complained physician did not submit any documentation regarding the origin of the 4,772 phone numbers of the recipients of the contested SMS message, which was the subject of the examined complaints, with content "... (FB: ...)". The physician made contradictory claims regarding the source of the numbers both to the Authority during the examination of the case and to the Hospital within the framework of the internal investigation: Specifically, within the framework of the internal investigation, the physician claimed that all the numbers came from a random number generator, while during his examination by the Authority, he initially claimed that 75% of the recipients of his message were personal acquaintances and friends; after comparing the list of his recipients with the list... at the Hospital from 2018 to 2023, and after it was established that the two lists matched by more than 70%, the physician argued that the term "personal friends and acquaintances" also includes the patients "of his", meaning the patients of the Hospital, whom he "treated" in a broad sense, that is, not only... but "served" as a physician in any way. It is noted that the physician did not provide any evidence regarding the origin of the numbers and their supposed quota by source of origin. Furthermore, the claim that the complained physician collected the patients' data himself and subsequently provided it to the Hospital's Secretariat (as an explanation for the inclusion of the same 17 incorrect numbers in both lists) contradicts the procedure described by the Hospital for the declaration and registration of patients' demographic data, according to which this information is declared only by the patients in person at the Hospital's reception and no intervention or modification of their file data by a third party is allowed. With the above contradictory claims,

24

which were constantly changing and adapting according to the stage of the investigation, so as to respond each time to the latest data available to the Authority, the complained data controller failed to substantiate, in accordance with the principle of accountability, the lawful collection and processing of the data (mobile phone number) of the recipients of his pre-election message. At the same time, from the elements of the case file, and taking into account in particular:

- a) the fact that the physician's list of recipients and the list... of Hospital X match by 70%, a particularly high percentage that cannot statistically be attributed to coincidence,
 - b) the fact that both lists contain 17 identical incorrect numbers, that is, consisting of a number of digits different from 10, and it is unlikely that the same error in registration has been repeated verbatim twice and that this specific "random" repetition of the same error occurs coincidentally in 17 cases, and
 - c) the fact that the procedure for collecting and registering patient data in the Hospital's program, as invoked by the physician, namely that the patient provides their information to the physician and the physician then gives it to the Secretariat, is not confirmed by the Hospital,
- it is a reasonable conclusion that the physician obtained the patients' contact information from the Hospital's records to which he had access, either acting alone (see reference in the context of the internal investigation, that according to the testimony of the head of the organization and information technology department, exporting data to Excel is not complicated) or utilizing the assistance of a third

party. However, even if, despite the absence of any evidence, the version ultimately supported by the complained physician were accepted, according to what he stated to the Authority during the 2nd hearing, since 2018, when he began serving at Hospital X, he systematically collected patient data from the Hospital and kept it for years in his personal "agenda", this processing took place without a clear and defined purpose, without a legal basis, and without informing the data subjects, violating the principles of...

25

of legality, objectivity, transparency, and purpose limitation (Articles 5 para. 1 a' and b' of the GDPR). Since the data in this case includes health information of the subjects (specifically that they are patients and belong to a specific category of diseases), they constitute special category data, for which an additional exception from the prohibition of processing would be required, according to Article 9 para. 2 of the GDPR. Regarding the claim of the reported physician that the legal basis for maintaining the patients' data in his own file was their legitimate interest concerning the immediate management and response to any questions/concerns... and that the processing was necessary for preventive or professional medical purposes (Article 6 para. 1 point f of the GDPR & Article 9 para. 2 point h of the GDPR), it is noted that, as the physician himself states right from the outset in his memorandum G/EIS/5613/02-07-2024, "for the medical file of the patients (...) the Data Controller is the Hospital itself" and not the respective physician. Furthermore, the use of a random number generator for the purpose of sending political communication messages does not constitute a lawful practice, nor was it provided as lawful under the previous regime, which the reported physician invokes (Guidelines 1/2019 of the Authority), while the sending of messages to recipients whose details have been drawn from publicly accessible directories does not meet the conditions for the application of the legal basis of Article 6 para. 1 f) of the GDPR, so as to rely on the alleged superior legitimate interest of the reported physician. It is noted that from the responses of the reported physician, it does not appear that there was a sufficient balancing between his legitimate interest in promoting his candidacy and the rights and freedoms of the recipients of the communication affected by the processing, as at no point did he mention that he took into account what the affected rights were. This processing of patient data could not reasonably be expected by the subjects, given that patients of a public hospital cannot be considered personal patients of the physician, in such a way that there exists a "relevant and appropriate relationship between the data subject and the data controller" (Recital 47 of the GDPR) and that the superior legitimate interest of the latter can be established in relation to the rights and freedoms of the subjects. Moreover, given that the purpose of collecting the data was, according to the physician's statement, to serve the subjects as patients, using them for the purpose of sending a political communication message constitutes a further purpose of processing, which in no case can be considered compatible with the original purpose under Article 6 para. 4 of the GDPR, taking into account the nature of the data (medical) and the legitimate expectations of each patient visiting a public hospital, who cannot reasonably expect that their phone number will be used in the context of the physician's election campaign who... served them in any way.

26

Additionally, in the context of sending the controversial pre-election message, it was found that the transparency obligations of the reported physician as the data controller were not fulfilled, according to Articles 13 and 14 of the GDPR. From the information available to the Authority, it appears that the only action taken by the reported physician to fulfill the transparency obligation was the posting of a text titled "INFORMATION NOTICE ON THE PROTECTION OF PERSONAL DATA" on the photos of his Facebook page on 19/5/2023, that is, after the sending of the message in question. In this notice, there is only reference to the processing of data based on consent and not based on the superior legitimate interest. It is noted that in the messages sent, there was no reference to any information text, nor was any other information provided. By exception, in the last two transmissions (4th and 5th communication), the following information is provided regarding the source of the data: "THE SOURCE OF YOUR TELEPHONE NUMBER IS THE GENERATOR OF RANDOM 10-DIGIT NUMBERS ekepis.gr". Based on the above, it is evident that the reported physician collected and processed

patient data from Hospital X for the purpose of political communication, in violation of the principle of legality, objectivity, and transparency of the processing. Beyond the above, from the examination of the case's elements, a violation of the obligation of the data controller under Article 12 para. 2 of the GDPR was found.

27

to facilitate the subjects in exercising their rights. In particular, the respondent claims that in the 1st communication, he referred the recipients to his Facebook page for this purpose (note with the phrase: “(FB: ...)” at the end of the message). However, this reference is not clear as to whether it pertains to the manner of exercising rights under the GDPR, while it is evident that if the recipient did not have a Facebook account, he would not have the ability to communicate with the respondent in this way. Furthermore, in the other communications (2nd – 5th), he did not provide any information regarding the manner of exercising the rights of objection or deletion of the recipients' data.

8. Therefore, the Authority finds the following violations on the part of the respondent physician, as the data controller:

- a) violation of the fundamental principle of legality, objectivity, and transparency of processing (Article 5(1)(a) in conjunction with Articles 6(1), 6(4), 9(1) and (2), 13 and 14 of the GDPR) and
- b) violation of the obligation to facilitate the subjects in exercising their rights (Article 12(2) of the GDPR).

9. Based on the above, the Authority deems it appropriate to exercise its corrective powers under Article 58(2) of the GDPR concerning the established violations and that, based on the circumstances identified, an effective, proportionate, and deterrent administrative monetary fine must be imposed, in accordance with the provision of Article 58(2)(h) of the GDPR, both for the restoration of compliance and for the punishment of the unlawful behavior. Furthermore, the Authority took into account the criteria for the imposition of fines set out in Article 83(2) of the GDPR, paragraphs 4(a) and 5(b) of the same article applicable to the present case, the Guidelines for the application and determination of administrative fines for the purposes of Regulation 2016/679 issued on 03-10-2017 by the Article 29 Working Party (WP 253), and the factual data of the examined case, particularly the criteria and special circumstances outlined below:

28

- that the established violations fall under the provision of paragraph 5 of Article 83 of the GDPR and specifically under case (a) of that paragraph concerning the fundamental principles of processing and under case (b) concerning the rights of data subjects
- that, taking into account the nature of the violation, which concerns the special category of health data, the number of affected subjects (at least 3,392 patients of the Hospital and in any case a total of 4,772 subjects without a legal basis) and the duration of the violation (the unlawful collection and retention of data by the respondent appears to have been occurring at least since 2018), the severity of the violation is deemed to be medium
- the high degree of responsibility of the physician, who, as a healthcare professional, is obliged to maintain medical confidentiality
- that the violation appears to be attributable to at least serious negligence on the part of the respondent physician

Aggravating factors taken into account:

- The presentation of contradictory claims that changed according to the evidence available to the Authority, from which an attempt to mislead the Authority and non-cooperation during the inspection is inferred.
- As noted, the physician bears a special obligation to maintain professional confidentiality (according to the wording of Article 9(3) of the GDPR). Therefore, the claim that he “did not have the means to obtain appropriate legal advice” before using the data for the purpose of political communication and that he fell “victim” to the advice of his communication consultants is taken into account as an aggravating factor in this case, as ignorance of the relevant provisions on data protection cannot be accepted from a professional who is obliged to maintain medical confidentiality.

- The repeated claim of the physician that he does not bear the burden of proof himself, despite the principle of accountability, which indicates not only ignorance but also a lack of willingness to comply with the GDPR.

Furthermore, it is taken into account that according to Recital 150 of the GDPR “In cases where administrative fines are imposed on individuals who are not businesses, the supervisory authority should take into account the general level of income in the member state, as well as the financial situation of the individual, when considering the appropriate amount of the fine.”

FOR THESE REASONS

THE AUTHORITY

Imposes on G, as the data controller, based on Article 58(2)(h) of the GDPR, a) an administrative fine of twelve thousand (12,000€) euros, for the established violation of the fundamental principle of legality, objectivity, and transparency of processing (Article 5(1)(a) in conjunction with Articles 6(1), 6(4), 9(1) and (2), 13 and 14 of the GDPR) and b) an administrative fine of three thousand (3,000€) euros, for the established violation of the obligation to facilitate the subjects in exercising their rights (Article 12(2) of the GDPR).

The President

The Secretary

Georgios Batzalexis

Irini Papageorgopoulou